IA agentique : jusqu’où peut-on déléguer sans perdre le contrôle ?

Pour un cadre d'assurance de l'exécution des processus critiques

Fabrice Pizzi — Swarm | Octobre 2026

L'autonomie progresse. Mais qu'en est-il de notre capacité à la maîtriser ?

Les progrès de l'intelligence artificielle agentique changent profondément notre manière de concevoir les systèmes informatiques.

Les modèles gagnent en capacité, les outils évoluent rapidement et les architectures multi-agents permettent d'automatiser des processus toujours plus complexes.

Une personne seule peut désormais développer des systèmes dont la réalisation aurait auparavant mobilisé plusieurs spécialistes pendant plusieurs mois.

Cette démocratisation est extraordinaire. Mais elle crée un déséquilibre.

Notre capacité à construire des systèmes autonomes progresse plus vite que notre capacité à démontrer que nous en maîtrisons l'exécution.

Un agent ne se contente plus de fournir une réponse.

Il peut décomposer un objectif, créer des sous-agents, appeler des outils, modifier des données, accéder à des services externes, conserver des expériences et poursuivre une mission pendant une période prolongée.

Cette autonomie introduit une nouvelle difficulté : nous ne pouvons plus supposer que chaque décision intermédiaire sera examinée par un humain.

La question n'est donc plus seulement de savoir si le modèle produit de bonnes réponses.

Elle devient : **dans quelles conditions peut-on lui permettre de produire des conséquences réelles ?**

Le problème n'est pas simplement la fiabilité du modèle

Les systèmes agentiques associent des mécanismes de raisonnement probabilistes à des environnements informatiques dont les règles de fonctionnement sont souvent déterministes.

Cette association est précisément ce qui les rend puissants.

Le modèle interprète, explore et propose. Les systèmes qu'il utilise exécutent des opérations concrètes.

Mais cette architecture crée une asymétrie fondamentale.

Une erreur de raisonnement peut rester bénigne tant qu'elle demeure une proposition. Elle change de nature lorsqu'elle devient un virement, une modification de droits, une suppression de données ou une commande adressée à une infrastructure.

Les mécanismes traditionnels de sécurité ne disparaissent pas. Ils deviennent au contraire indispensables.

Authentification, autorisation, séparation des privilèges, isolation des processus, vérification des transactions et journalisation doivent être appliquées à une nouvelle catégorie d'acteurs : des programmes capables de déterminer dynamiquement leurs prochaines actions.

À cela s'ajoute une difficulté particulière.

Dans un système agentique, les informations qui influencent une décision peuvent évoluer pendant l'exécution.

Un document externe peut contenir une injection de prompt. Un résultat d'outil peut être trompeur. Un résumé transmis entre agents peut perdre sa provenance. Une mémoire persistante peut conserver une procédure erronée ou malveillante et la réintroduire plusieurs sessions plus tard.

L'OWASP décrit ces risques dans son Top 10 pour les applications agentiques, notamment à travers le détournement d'objectif, les abus de privilèges, l'empoisonnement de mémoire et les défaillances en cascade.

Ces catégories mettent en évidence une propriété essentielle : **une information n'acquiert pas une autorité du seul fait qu'un agent l'a mémorisée, répétée ou transmise.**

De la sécurité des agents à l'assurance de leurs effets

La recherche et les initiatives de standardisation commencent à apporter des réponses importantes.

Le projet CaMeL, de Debenedetti et ses coauteurs, montre l'intérêt d'une séparation explicite entre flux de contrôle et flux de données, associée à des capacités restreignant les appels d'outils.

AgentSpec explore l'application de contraintes déclaratives pendant l'exécution.

L'OWASP Agent Control Standard, publié en septembre 2026, définit un protocole d'interception et de décision permettant à un Guardian de contrôler les opérations d'un agent.

SPIFFE apporte des identités vérifiables pour les workloads. Les standards OAuth permettent d'exprimer des autorisations structurées et des délégations.

NVIDIA OpenShell propose des politiques de confinement des fichiers, processus et accès réseau.

Enfin, un Internet-Draft individuel déposé par Sangam Das en septembre 2026 propose une architecture d'autorisation graduée et de contrôle de l'engagement final des actions critiques.

Ces travaux montrent que le problème est identifié et que les réponses techniques progressent.

Ces références n'ont toutefois pas toutes le même statut. ISO/IEC 27001 et 42001 définissent des exigences de systèmes de management ; ISO/IEC 23894 fournit des recommandations de gestion des risques. Le Top 10 agentique classe des risques, tandis qu'ACS spécifie des mécanismes de contrôle à l'exécution. SPIFFE traite de l'identité des workloads, et OWASP ASVS fournit des exigences de vérification pour les applications et services web. Ces apports sont complémentaires. [1–3, 9, 12–13]

ACS décrit déjà une couche déterministe, avec un recours optionnel à un LLM. La séparation entre raisonnement et contrôle est donc un principe partagé. L'apport recherché avec Swarm porte sur sa continuité dans les parcours effectivement réalisés : autorité, contenu approuvé, engagement, preuve et reprise après incident. [2]

Une correspondance documentaire avec un référentiel, une compatibilité testée avec une version précise et une certification sont trois affirmations différentes. Une organisation peut structurer son management de l'IA sans que cela démontre la sécurité de chaque action produite par son système.

Le NIST a lancé son AI Agent Standards Initiative le 17 février 2026. Ses travaux sur l'identité et l'autorisation alimentent cette construction collective ; ils ne constituent pas à eux seuls une certification de sécurité agentique. De même, l'Internet-Draft individuel de Sangam Das reste une proposition de recherche sans approbation normative de l'IETF. [3, 6, 14]

Il serait donc inexact d'affirmer que les standards sont inexistants.

En revanche, **l'existence de mécanismes de contrôle ne démontre pas encore leur continuité sur l'ensemble du cycle de vie d'un processus agentique**.

Une identité peut être authentifiée sans que l'action soit autorisée.

Une action peut avoir été approuvée puis modifiée avant son exécution.

Une mémoire peut conserver des données intègres mais mensongères.

Une décision de refus peut être contournée par un autre connecteur.

Une transaction peut avoir été exécutée alors que l'agent, après une panne, croit devoir la recommencer.

C'est cette continuité qu'il faut désormais considérer comme une propriété de sécurité à part entière.

Qu'est-ce qu'un processus critique dans un système agentique ?

Je propose de ne pas limiter cette notion aux seules infrastructures officiellement classées critiques.

Un processus métier peut présenter une criticité élevée sans appartenir à un secteur réglementé particulier.

Je retiendrais la définition suivante :

Un processus agentique critique est un ensemble d'activités dans lequel une action incorrecte, non autorisée, répétée ou insuffisamment contrôlée peut provoquer une conséquence grave pour les personnes, les droits, les finances, la confidentialité, la sûreté ou la continuité d'un service essentiel.

Cette définition repose sur la conséquence possible, et non sur la technologie employée.

Elle concerne notamment :

- Les transferts financiers, règlements et modifications de bénéficiaires.
- Les décisions ou opérations affectant directement la santé et la sécurité des personnes.
- Les commandes industrielles et les modifications de systèmes assurant des fonctions de sûreté.
- Les changements de privilèges dans des infrastructures sensibles.
- La divulgation ou la destruction de données dont la compromission aurait des conséquences graves.
- Les décisions administratives ou contractuelles affectant significativement les droits d'une personne.
- Les modifications de services essentiels, de leurs contrôles de sécurité ou de leurs mécanismes de restauration.

La criticité ne dépend pas uniquement du montant d'une transaction ou de la sensibilité d'un outil.

Un ensemble d'opérations apparemment limitées peut produire un effet critique par accumulation.

Dix opérations individuellement admissibles ne constituent pas nécessairement une opération globale autorisée.

Le contrôle doit donc porter sur la trajectoire complète du processus, ses dépendances, ses délégations et ses effets cumulés.

Autre point essentiel : **l'assistance agentique et l'engagement autonome doivent être distingués**.

Un agent peut analyser une situation critique sans avoir le droit de modifier le système concerné.

Il peut préparer une proposition d'action sans disposer des moyens techniques nécessaires pour l'exécuter.

Cette séparation permet de bénéficier des capacités de l'IA sans lui transférer automatiquement l'autorité associée aux systèmes métier.

Trois responsabilités : les règles, les clés et les barrières

Dans les deux précédents articles consacrés à Swarm, j'ai présenté le rôle de son moteur déterministe Rust, puis les questions d'identité et de mémoire persistante.

Je voudrais maintenant élargir cette réflexion.

Une architecture de contrôle agentique devrait distinguer trois responsabilités fondamentales.

Le gardien des règles

Il vérifie les conditions dans lesquelles une action peut être autorisée.

Il applique des politiques explicites, versionnées et indépendantes du raisonnement du modèle.

Il contrôle l'identité de l'acteur, sa délégation, les ressources concernées, les dépendances, les restrictions métier et les validations exigées.

Son fonctionnement déterministe ne garantit pas que ses règles sont correctes. Il permet en revanche de vérifier que la même règle est appliquée selon les mêmes conditions.

Le gardien des clés

Il conserve les capacités techniques permettant de produire des effets sensibles.

Un agent chargé de préparer un paiement n'a aucune raison de posséder directement les identifiants permettant de déclencher ce paiement.

Un agent de développement n'a pas nécessairement besoin de disposer des secrets de production.

Ces capacités doivent être protégées et délivrées uniquement pour des opérations précises, sous des conditions définies.

Le contrôle des secrets n'est donc pas une simple mesure de confidentialité.

Il constitue une séparation des pouvoirs entre l'agent qui propose et le composant qui peut agir.

Les garde-barrières

Ils appliquent effectivement les décisions à la frontière des ressources protégées.

Une politique de refus n'offre aucune garantie si l'agent peut emprunter un autre chemin d'exécution.

Les accès aux fichiers, au réseau, aux outils, aux services métier et aux opérations privilégiées doivent être médiatisés par des mécanismes que l'agent ne peut pas modifier ou désactiver avec ses propres permissions.

Ce principe rejoint celui du moniteur de référence et des points d'application des politiques du Zero Trust.

La distinction entre les trois fonctions est logique : elles peuvent partager des composants physiques si leur architecture préserve réellement leurs propriétés de sécurité.

L'important n'est pas le nombre de services. C'est l'impossibilité de contourner les fonctions de contrôle.

Une approbation doit suivre l'action exacte

Prenons une facture pour laquelle un agent prépare un règlement. Le montant, la devise et le bénéficiaire sont approuvés. Un courriel annonce ensuite de nouvelles coordonnées bancaires et l'agent modifie sa proposition.

L'autorisation initiale doit rester liée au contenu qui a été examiné. Changer le bénéficiaire, le montant ou un autre paramètre protégé doit invalider l'accord correspondant et déclencher les contrôles requis sur la nouvelle demande.

Le service qui engage l'effet doit vérifier une dernière fois le mandat courant, la politique applicable et les approbations exactes au dernier point où il peut encore empêcher l'opération. Une révocation prise en compte avant ce point doit empêcher un nouvel engagement ; elle ne permet pas d'effacer un effet déjà engagé.

Si le paiement a été exécuté mais que la réponse est perdue, une nouvelle requête ne constitue pas une reprise sûre. Il faut conserver une intention métier durable, un identifiant d'opération et une issue connue ou inconnue, puis réconcilier l'état avant toute répétition susceptible de produire un second effet.

L'idempotence doit être vérifiée là où l'effet est réellement engagé. Une clé locale ne suffit pas si le service externe peut encore exécuter deux opérations distinctes. ACRFence étudie justement les risques de rejeu et de réutilisation d'autorité lorsque des agents restaurés reconstruisent des appels différents. Ses résultats restent liés au périmètre étudié. [7]

La mémoire doit entrer dans le périmètre de sécurité

C'est probablement l'un des aspects que les architectures agentiques devront approfondir.

Une mémoire persistante n'est pas seulement un mécanisme d'optimisation du contexte.

Elle participe au comportement futur de l'agent.

Elle peut conserver des préférences, des décisions, des procédures, des résultats antérieurs ou des expériences présentées comme réussies.

Dès qu'une mémoire influence une action future, son intégrité, sa provenance et ses droits d'usage deviennent des propriétés du processus.

Dans Swarm, je cherche notamment à distinguer :

- L'identité de l'agent et les droits qui lui sont accordés.
- L'origine et la version d'une information mémorisée.
- Les conditions de lecture, de résumé et de transmission.
- Le contexte effectivement préparé pour une tentative.
- Les règles qui gouvernent l'action résultante.

Le modèle de Biba fournit ici une référence historique utile pour raisonner sur les niveaux d'intégrité.

Mais Biba, une signature cryptographique ou un contrôle de provenance ne prouvent pas qu'un souvenir est sémantiquement correct.

L'architecture doit donc préserver une frontière : une information, même authentifiée, ne peut pas créer d'autorisation par elle-même.

Le contenu peut contribuer au raisonnement.

Il ne doit pas modifier seul les règles qui gouvernent les conséquences de ce raisonnement.

La révocation d'une mémoire doit également être décrite avec précision. Elle peut empêcher de nouveaux usages contrôlés ; elle ne supprime pas rétroactivement ce qui a déjà été transmis à une conversation ou à un fournisseur. Une reprise doit donc tenir compte des versions et du contexte effectivement reçus.

Biba fournit un modèle de contrôle des flux d'intégrité. Il ne garantit ni la confidentialité, ni la vérité d'un contenu, ni une séparation sémantique générale entre données et instructions. Ces propriétés demandent des mécanismes et des preuves complémentaires.

Proposition : PAEA, un profil d'assurance de l'exécution agentique

À partir de ces constats, je propose un premier cadre de travail :

PAEA — Profil d'Assurance de l'Exécution Agentique.

Son objectif n'est pas de remplacer les standards existants.

Il consiste à les articuler autour d'une propriété centrale :

Toute action critique produite par un système agentique doit rester sans effet tant que son identité, son autorité, son contenu exact et ses conditions d'engagement n'ont pas été vérifiés par une chaîne de contrôle non contournable.

Le framework couvre également ce qui précède l'action et ce qui lui succède.

Avant l'action : classification de criticité, identité, mandat, provenance et contexte.

Pendant l'action : contrôles d'autorisation, approbations, capacité d'exécution limitée et vérification au dernier point permettant d'empêcher l'effet.

Après l'action : résultat observé, preuve, réconciliation, supervision et reprise.

La proposition s'appuie sur des invariants vérifiables plutôt que sur une confiance déclarée envers les modèles.

Elle distingue plusieurs niveaux d'assurance proportionnés aux conséquences possibles.

Ces niveaux restent à spécifier et à éprouver. À ce stade, PAEA constitue une proposition de profil d'assurance ; aucun barème, label de conformité ou niveau de certification n'est acquis par son seul énoncé.

Elle impose enfin une qualification fondée sur des scénarios adversariaux, des tests reproductibles et l'identification exacte de la version évaluée.

Le modèle lui-même peut changer. Ses performances peuvent progresser.

Les garanties d'autorité et d'exécution doivent rester indépendantes de ces évolutions.

Huit exigences à rendre vérifiables

Pour transformer PAEA en un cadre testable, je propose de conserver huit exigences complémentaires.

1. Une identité vérifiable et une chaîne d'autorité explicite. Chaque instance doit être rattachée à un principal authentifié, un mandat et une portée. La création d'un sous-agent doit respecter les droits délégables du parent. Une consigne ou un message ne peut pas augmenter ces droits.

2. Une intégrité des données et une admission contrôlée. La provenance et le niveau de confiance des documents, messages et résultats d'outils doivent être connus. Leur admission à un niveau d'intégrité supérieur exige une procédure explicite, attribuée et liée à l'original. Un champ déclaré par l'agent ne constitue pas une autorité.

3. Une mémoire persistante gouvernée. Chaque mémoire réutilisable doit conserver sa provenance, sa version, sa portée et ses conditions d'usage. Lire, résumer et transmettre sont des opérations dont les droits doivent être vérifiés. Le retrait bloque les nouveaux usages concernés sans réécrire les contextes déjà transmis.

4. Un contrôle indépendant au point d'engagement. Les opérations sensibles doivent être proposées sous une forme structurée. Le contrôle doit vérifier la politique courante et les conditions exactes jusqu'au moment où l'effet peut encore être empêché. Une panne de ce contrôle ne doit pas libérer l'action sensible.

5. Des capacités limitées et des voies d'accès maîtrisées. Les secrets critiques restent détenus par des composants protégés. Les accès directs et alternatifs par outil, processus, fichier, réseau ou connecteur doivent être inventoriés et éprouvés. Une télémétrie qui observe l'effet après coup ne démontre pas qu'elle pouvait l'empêcher.

6. Une maîtrise des effets et des reprises. Chaque intention sensible doit posséder une identité durable, une autorisation liée à son contenu et un état vérifiable. Une issue inconnue exige une réconciliation avant toute répétition susceptible de produire un doublon. Les garanties du connecteur réel font partie du périmètre évalué.

7. Une validation humaine effective lorsqu'elle est requise. L'approbation doit être authentifiée et liée à l'opération exacte. La séparation demandeur et approbateur doit être vérifiée lorsque la politique l'exige. Une revue IA favorable ne remplace pas cette décision humaine.

8. Des preuves protégées et une qualification reproductible. Chaque effet observé doit pouvoir être relié à son objectif, son acteur, son mandat, la politique, la décision et les versions de données concernées. L'altération et l'omission de preuves doivent être traitées selon un modèle de menace déclaré.

Ces exigences doivent être évaluées sur le système complet concerné. Une frontière entre modules ne suffit pas si les permissions de l'agent lui permettent de modifier les politiques, de récupérer les clés ou d'altérer les preuves. Les hypothèses sur le même utilisateur système, l'administrateur de l'hôte et les services externes doivent rester explicites.

Pourquoi Swarm ?

Je positionne Swarm autour d'une idée :

Organiser le travail des agents et rendre vérifiables les conditions dans lesquelles ils peuvent agir.

Swarm est un moteur d'orchestration multi-agents à contrôle déterministe.

Il vise à relier chaque action à une identité, une autorité, un contenu approuvé et un résultat vérifiable, avec des mécanismes de supervision et de reprise.

Son moteur Rust porte des contrôles et des transitions qui restent distincts des propositions des modèles.

Les travaux sur la mémoire, les contrats d'identité et les actions de confiance cherchent à étendre cette séparation à des processus complets.

Swarm est toutefois un projet en évolution.

Au 25 octobre 2026, le plan BIBA-RUST consigne la livraison locale du noyau des actions de confiance : moniteur I0–I3, identités locales, mandats, accords exacts, deux connecteurs à effets simulés, idempotence et réconciliation, avec des parcours CLI, API et web. Ces preuves portent sur le périmètre évalué ; elles ne démontrent ni paiement réel, ni attribution de droits externes, ni confinement général des agents. [11]

Le plan AC-02 de confinement et de médiation réseau et secrets est enregistré, sans démarrage. La référence à OpenShell ou à une politique YAML ne suffit pas à établir une protection active dans Swarm. Les parcours complets d'identité et d'usage de la mémoire restent à qualifier. [11]

Une matrice relie déjà douze contrôles NIST sélectionnés à des preuves locales contextualisées. Elle conserve ses écarts et ne sélectionne aucune baseline de conformité. PAEA peut prolonger cette matrice en reliant chaque exigence à un mécanisme, un propriétaire et une preuve, sans transformer les résultats partiels en certification. [11]

Les garanties actuellement disponibles sont établies sur des parcours précis et des versions identifiées. Les mécanismes d'identité, de mémoire et de confinement ne sont pas encore tous qualifiés de bout en bout.

Il serait prématuré de présenter Swarm comme un système certifié pour des processus critiques.

Son intérêt, dans le cadre de cette recherche, est de constituer un terrain d'expérimentation sur lequel les propriétés proposées pourront être implémentées, attaquées, mesurées et comparées à d'autres approches.

Faut-il suspendre l'exécution autonome des processus critiques ?

Ma position est la suivante.

Nous ne devrions pas autoriser un système agentique à engager directement des actions critiques lorsque les garanties nécessaires à leur contrôle n'ont pas été démontrées.

Cela ne signifie pas interdire l'usage de l'IA dans les domaines sensibles.

Cela signifie distinguer ce que le système peut analyser, ce qu'il peut préparer, ce qu'il peut recommander et ce qu'il peut effectivement exécuter.

L'autonomie d'engagement devrait dépendre d'un niveau d'assurance explicite.

Pour certaines opérations, une autorisation préalable limitée et un contrôle déterministe suffiront peut-être.

Pour d'autres, il faudra une validation humaine indépendante.

Pour les fonctions de sûreté les plus sensibles, le framework ne pourra pas remplacer les exigences de certification et les dispositifs de protection propres au domaine.

Cette approche suppose d'accepter un coût supplémentaire de contrôle.

Mais l'optimisation de la vitesse d'exécution n'est pas le seul objectif d'un processus critique.

L'enjeu est de rendre l'autonomie compatible avec la responsabilité.

De l'expérimentation à une proposition vérifiable

Le prochain travail consiste à transformer PAEA en spécification technique.

Il faudra définir les invariants, les frontières de confiance, les conditions de déploiement et les scénarios de qualification.

Puis comparer plusieurs architectures : agents disposant directement des outils, contrôle des appels d'outils, workflow déterministe et contrôle complet du cycle de vie.

Les mesures devront porter sur les effets indésirables réellement observés, les blocages injustifiés, les coûts, la latence et la capacité à reprendre correctement après incident.

Chaque fiche d'évaluation devra identifier la version et l'empreinte du binaire, sa configuration, les références retenues, le modèle de menace, les exigences applicables et les preuves. Les tests devront conserver un témoin valide, les refus attendus et les conditions de reprise.

Les scénarios doivent notamment couvrir une modification après approbation, une révocation concurrente, une injection de prompt, une mémoire contaminée, un accès direct contournant le connecteur, une panne du contrôle et une réponse perdue après engagement. Ils doivent mesurer l'effet réellement observé, au-delà du seul code de retour.

Une unité réussie, une simulation locale, une intégration avec un service réel et une évaluation indépendante doivent conserver des statuts distincts. L'absence de preuve laisse le critère ouvert ; un pourcentage moyen ne compense pas l'échec d'un invariant nécessaire.

Une série de tests réussis ne constituera pas une preuve universelle de sécurité.

Elle permettra néanmoins de formuler des garanties bornées, reproductibles et réfutables.

C'est ce type de démonstration qui doit accompagner le développement de l'autonomie agentique.

Nous avons consacré beaucoup d'efforts à apprendre aux agents à raisonner et à agir.

Il devient nécessaire de consacrer autant d'efforts à **définir les conditions vérifiables dans lesquelles nous acceptons de leur laisser produire des conséquences**.

La vraie question n'est pas de savoir si l'IA agentique deviendra suffisamment capable pour piloter nos processus critiques.

Elle est de savoir si nous construirons, avant de lui en confier les clés, les mécanismes qui garantissent que ces clés ne pourront pas être utilisées hors de l'autorité accordée.

Swarm — orchestrer les agents, contrôler leur autorité, vérifier leurs effets.

Références principales

[1] OWASP GenAI Security Project, *Top 10 for Agentic Applications*, 2026.

Source 1

[2] OWASP, *Agent Control Standard*, spécification v0.1.0, 2026.

Source 2

[3] NIST, *AI Risk Management Framework*, 2023, et travaux sur l'identité agentique et les infrastructures critiques, 2026.

Source 3

[4] Debenedetti et al., *Defeating Prompt Injections by Design*, CaMeL, arXiv:2503.18813.

Source 4

[5] Wang et al., *AgentSpec: Customizable Runtime Enforcement for Safe and Reliable LLM Agents*, arXiv:2503.18666.

Source 5

[6] Das, *Adaptive Authorization for Agentic AI: Graduated and Escalated Execution Control for Critical Infrastructure*, Internet-Draft individuel, septembre 2026.

Source 6

[7] Zheng et al., *ACRFence: Preventing Semantic Rollback Attacks in Agent Checkpoint-Restore*, arXiv:2603.20625.

Source 7

[8] Agent Baseline, *The Secure Software Factory: A Reference Architecture*, version 1, octobre 2026.

Source 8

[9] ISO/IEC 42001:2023, ISO/IEC 23894:2023 ; NIST SP 800-207 ; SPIFFE ; RFC 8693 et RFC 9396.

Source 9

[10] ANSSI, *Recommandations de sécurité pour un système d'IA générative*, avril 2024.

Source 10

[11] Documentation d'architecture et contrats de Swarm, état d'octobre 2026.

[12] ISO/IEC 27001:2022, systèmes de management de la sécurité de l'information. Source.

[13] OWASP, Application Security Verification Standard, version 5.0.0. Source.

[14] NIST, AI Agent Standards Initiative, annonce du 17 février 2026 ; point sur l'identité et l'autorisation du 29 septembre 2026. Initiative ; identité et autorisation.